

Unauthorised Cloud Database Snapshot Exports

response

Intrusion · **Critical** severity · SOC IR Playbook

Incident type	Data Exposure - Snapshot Abuse
Severity	Critical
Priority	Critical
Detection sources	Cloud Audit Logs, CSPM Alerts, SIEM, Storage Logs, Database Activity Monitoring Tools

Scenario

A cloud database snapshot (e.g., AWS RDS snapshot, Azure SQL Database export, GCP Cloud SQL backup) is created or shared without approval. This may lead to sensitive data exfiltration if the snapshot is exposed to unauthorised users or shared publicly.

MITRE ATT&CK

T1005, T1048, T1078.004, T1530

Preparation

Enforce snapshot encryption Use customer-managed KMS keys and enforce encryption on all snapshots Restrict snapshot sharing Apply org-level policies to disallow public or cross-account snapshot sharing Monitor snapshot creation Alert on snapshot exports, shares and downloads using CSPM or SIEM Tag sensitive databases Classify resources for targeted monitoring and DLP enforcement Enable Cloud Audit Logging Ensure all snapshot-related actions (create, share, restore) are logged

Detection & Analysis

Alert triggered Snapshot shared outside of organisation or created at unusual time/user Investigate snapshot type and target Determine which DB was snapped and whether the snapshot was shared publicly or to unknown accounts Review access logs Check if snapshot has been downloaded, restored or accessed Correlate with user identity Investigate the IAM identity or service account that performed the action

Containment

Revoke access to shared snapshot Remove sharing or make the snapshot private via console or CLI Suspend offending account Temporarily disable user or service account responsible Disable download access If snapshot was copied to an external S3 bucket, GCS or Azure blob, revoke access Alert compliance and legal teams Especially if data subject to regulatory protection was involved

Eradication

Delete unauthorised snapshots Remove rogue or unapproved copies Rotate affected credentials If secrets were part of the database content or if service account was abused Audit IAM permissions Ensure snapshot creation and sharing are tightly scoped to trusted roles only Review cross-account trust settings Remove any risky or unmonitored permissions that allow sharing outside the organisation

Recovery

Restore trusted backup procedures Reinstate verified, encrypted and access-controlled backups Revalidate database and snapshot integrity Ensure no tampering or backdoors were introduced via restore processes Resume database operations Once the environment and backups are secure and validated Increase logging around critical databases Apply heightened surveillance for a defined observation period

Lessons Learned & Reporting

Document incident scope Timeline, data types exposed, accounts involved and resolution steps Update detection rules Add alerts for snapshot sharing or copying across boundaries Train DB admins and developers On secure snapshot procedures and IAM governance Report to authorities If breach involves personal, financial or government-regulated data Improve cloud guardrails Use Infrastructure-as-Code scanning and policy-as-code for future prevention

Tools typically involved

Cloud-native logs (e.g., AWS CloudTrail, Azure Activity Logs, GCP Admin Audit Logs); CSPM (e.g., Wiz, Prisma Cloud, Microsoft Defender for Cloud); SIEM (e.g., Sentinel, Splunk); DLP tools (e.g., Microsoft Purview, Forcepoint DLP); SOAR platform for automated response; Database Activity Monitoring (e.g., Imperva, Guardicore, native platform logging)

Success metrics (SLA targets)

Detection Time <10 minutes from snapshot creation or share Public Access Removal Time <30 minutes from confirmation Snapshot Deletion Time <1 hour for unauthorised snapshots IAM Policy Audit Completion 100% of affected environments within 48 hours Compliance Notification Deadline Within 72 hours or as per regulatory requirements